

Worksheet 1: Individual Weakness Audit Log

Part A — Exhibit A: Product Requirements Document (PRD)

Finding 1.1 (Required)

Target Document & Section	Document: PRD (Exhibit A) Section: FR-28, Certificate Management
Taxonomy Code & Category	Code: D Category: Design Leak
Severity Level	Major (P2)
Quoted Evidence (Verbatim Text)	<i>"Uploaded certificates are stored on Kubernetes PersistentVolume and linked to the user's anonymous ID."</i>
Diagnosis (Why is this flawed?)	A PRD isn't supposed to say how something gets built, only what it needs to do. Naming "Kubernetes PersistentVolume" already picks the infrastructure before anyone designed it. This is basically the same example the taxonomy guide uses for this code.
Downstream Impact (What breaks if built?)	If the team ever has to move off Kubernetes, they'd have to go edit the PRD too, when the PRD is supposed to stay the same no matter what tech ends up being used.

Finding 1.2 (Required)

Target Document & Section	Document: PRD (Exhibit A) Section: SC-1 (Success Criteria) vs. NFR-1 (Non-Functional Requirements)
--------------------------------------	--

Taxonomy Code & Category	Code: C Category: Contradiction
Severity Level	Critical (P1)
Quoted Evidence (Verbatim Text)	<i>"SC-1: "Fence cascade triggers within 60 seconds of a symptom report." / NFR-1: "The promotion cascade completes within 1 second for a graph of up to 10,000 active nodes.""</i>
Diagnosis (Why is this flawed?)	SC-1 says the whole fencing cascade should trigger within 60 seconds, but NFR-1 says the cascade finishes in 1 second. Neither section says if these are the same step or two different ones (computing the cascade vs. actually notifying people), so both numbers can't both be true.
Downstream Impact (What breaks if built?)	QA won't know which number to test against. Whatever the team builds, someone can reasonably say it doesn't match what was promised.

Finding 1.3 (Required)

Target Document & Section	Document: PRD (Exhibit A) Section: FR-2, Contact Detection & Circle Management
Taxonomy Code & Category	Code: A Category: Ambiguity
Severity Level	Major (P2)
Quoted Evidence (Verbatim Text)	<i>"Professors/Admins must have a "Circle Dashboard" displaying event details, active participant lists, capacity counters, manual addition capabilities, and a scannable QR code."</i>
Diagnosis (Why is this flawed?)	It doesn't say if a professor only sees their own circles or every circle campus-wide, and it doesn't say if "Admin" means an admin of one circle or an admin of the whole platform. The slash between "Professors/Admins" hides that difference.

Downstream Impact (What breaks if built?)	A developer could reasonably build a dashboard where any professor sees the participant list of a class they don't teach, which is a privacy issue the document never flags.
--	--

Finding 1.4 (Required)

Target Document & Section	Document: PRD (Exhibit A) Section: DR-1, Privacy Compliance
Taxonomy Code & Category	Code: G Category: Domain / NFR Gap
Severity Level	Critical (P1)
Quoted Evidence (Verbatim Text)	<i>"System complies with FERPA (Family Educational Rights and Privacy Act) for student data."</i>
Diagnosis (Why is this flawed?)	The system handles health data too (symptoms, test results, medical certificates), not just academic records. FERPA only covers academic records. There's no mention of HIPAA or anything similar anywhere in the document, even though health data is basically the whole point of the product.
Downstream Impact (What breaks if built?)	The system could check every FERPA box on paper and still be mishandling sensitive medical information, which is a real legal risk for the university.

Finding 1.5 (Required)

Target Document & Section	Document: PRD (Exhibit A) Section: FR-17, Campus Entry & Visitor Management vs. DR-2 / DR-4, Privacy Compliance
Taxonomy Code & Category	Code: C Category: Contradiction
Severity Level	Critical (P1)

Quoted Evidence (Verbatim Text)	<i>"FR-17: "...a secure backend REST API endpoint for creating a local database account and linking biometrics." / DR-2: "All contact graph data uses non-reversible anonymous IDs (salted hashing)."</i>
Diagnosis (Why is this flawed?)	Linking biometrics to someone's account is basically the opposite of anonymous — biometrics identify a person and can't be un-linked. But DR-2 says everything in the contact graph has to be a non-reversible anonymous ID. The document asks for both things at once without explaining how they coexist.
Downstream Impact (What breaks if built?)	If this gets built as written, the core privacy promise breaks right at visitor sign-up, which is the group with the least institutional protection to begin with.

Part B — Exhibit B: UX Design Specification

Finding 1.1

Target Document & Section	Document: UX Design Specification (Exhibit B) Section: 2.1, Defining Experience
Taxonomy Code & Category	Code: V Category: Vagueness
Severity Level	Major (P2)
Quoted Evidence (Verbatim Text)	<i>"This should feel like a 'Magic Door.'"</i>
Diagnosis (Why is this flawed?)	"Magic Door" doesn't say anything measurable — no timing, no feedback, no way to know when it's actually "done." Two designers could read this line and build completely different things.
Downstream Impact (What breaks if built?)	UX and engineering could end up building two different versions of the same experience, and QA has nothing solid to test it against.

Finding 1.2

Target Document & Section	Document: UX Design Specification (Exhibit B) Section: Experience Principles
Taxonomy Code & Category	Code: U Category: Untestability
Severity Level	Major (P2)
Quoted Evidence (Verbatim Text)	<i>"Zero-Friction Compliance: Interactions must take less than 5 seconds."</i>
Diagnosis (Why is this flawed?)	It says under 5 seconds, but doesn't say where the timer starts or stops. Does that include typing, logging in, waiting on the network, or just the closing animation?
Downstream Impact (What breaks if built?)	Different QA people could time different parts of the flow and get different pass/fail results for the exact same feature.

Finding 1.3

Target Document & Section	Document: UX Design Specification (Exhibit B) Section: 2.4, Novel UX Patterns
Taxonomy Code & Category	Code: D Category: Design Leak
Severity Level	Major (P2)
Quoted Evidence (Verbatim Text)	<i>"Biometric Web-to-App Handoff: Instant Upgrade flow from web to native via FaceID/TouchID."</i>
Diagnosis (Why is this flawed?)	This locks in FaceID/TouchID as the only way to do the handoff, before checking if every target device even supports that. That's a UX document making a technology decision it shouldn't be making.

Downstream Impact (What breaks if built?)	Any device without that hardware needs a whole separate flow that nobody planned for, which means more rework down the line.
--	--

Finding 1.4

Target Document & Section	Document: UX Design Specification (Exhibit B) Section: 4.6, Professor Circle Dashboard
Taxonomy Code & Category	Code: I Category: Incompleteness
Severity Level	Critical (P1)
Quoted Evidence (Verbatim Text)	<i>"Participant List: Scrollable list showing user names with visual status indicators."</i>
Diagnosis (Why is this flawed?)	It just says "user names" without saying who's allowed to see them. That matters a lot here, since the whole product is built around anonymity.
Downstream Impact (What breaks if built?)	Real names or health-related info could end up visible to someone who shouldn't see them, which is a serious enough privacy problem to force a redesign of the dashboard.

Finding 1.5

Target Document & Section	Document: UX Design Specification (Exhibit B) Section: 2.3, Success Criteria / 4.1, Frictionless Campus Entry
Taxonomy Code & Category	Code: U Category: Untestability
Severity Level	Major (P2)

Quoted Evidence (Verbatim Text)	<i>"The 'Walking Pace' Benchmark: Successful scan in under 200ms."</i>
Diagnosis (Why is this flawed?)	Same issue as the 5-second requirement: 200ms sounds precise but doesn't say what's actually being measured. QR detection? Server validation? Visual feedback? The gate opening?
Downstream Impact (What breaks if built?)	Nobody can build a consistent test for this, and the team could end up optimizing the wrong part of the flow while the real bottleneck (gate congestion) stays unsolved.

Part C — Exhibit C: Architecture Decision Document

Finding 1.1 (Required)

Target Document & Section	Document: Architecture (Exhibit C) Section: Mobile Architecture (Expo/React Native)
Taxonomy Code & Category	Code: X Category: Cross-Document Inconsistency
Severity Level	Critical (P1)
Quoted Evidence (Verbatim Text)	<i>"Offline Support: Not required (Phase 1). Deferred to Phase 2."</i>
Diagnosis (Why is this flawed?)	UX promises offline QR tokens as part of the main entry flow, and calls that flow the "Defining Experience." Architecture says the opposite: no offline support until Phase 2. Same feature, same phase, two different answers.
Downstream Impact (What breaks if built?)	If it's built exactly as Architecture says, a student with no signal at the gate can't get in. Nobody's likely to catch this until integration testing, or worse, during an actual network outage in production.

Finding 1.2 (Required)

Target Document & Section	Document: Architecture (Exhibit C) Section: Authentication Flow
Taxonomy Code & Category	Code: I Category: Incompleteness
Severity Level	Critical (P1)
Quoted Evidence (Verbatim Text)	<i>"3. Returns JWT with { sub: anonymousId, permissions: [...], roles: [...] }"</i>
Diagnosis (Why is this flawed?)	The flow validates someone through LDAP (which returns a real, identifiable university login) and ends up handing back a JWT with an anonymousId. But nowhere does it say how you get from that real LDAP identity to the anonymous ID. That step is just missing.
Downstream Impact (What breaks if built?)	Whoever builds this has to invent their own way of doing it, with a real risk that someone's actual username or email ends up logged or cached somewhere along the way, breaking the whole anonymity guarantee.

Finding 1.3 (Required)

Target Document & Section	Document: Architecture (Exhibit C) Section: Cross-Cutting Concerns
Taxonomy Code & Category	Code: M Category: Missing / Traceability
Severity Level	Major (P2)
Quoted Evidence (Verbatim Text)	<i>"5. Multi-Campus Potential — Architecture should support future multi-tenant deployment."</i>
Diagnosis (Why is this flawed?)	Multi-campus support is listed as something the architecture needs to handle, but nothing after that (not the data model, not the services, not the naming conventions) actually separates one university's data from another's.

Downstream Impact (What breaks if built?)	If multi-campus really is the plan, retrofitting it later means rebuilding the data model and the identity vault instead of designing tenant isolation in from day one.
--	---

Finding 1.4 (Required)

Target Document & Section	Document: Architecture (Exhibit C) Section: Authentication & Security, Audit
Taxonomy Code & Category	Code: G Category: Domain / NFR Gap
Severity Level	Critical (P1)
Quoted Evidence (Verbatim Text)	<i>"Audit: Kafka audit topic + PostgreSQL audit table — Immutable logging"</i>
Diagnosis (Why is this flawed?)	It calls the audit log "immutable" but never says how. No retention period, no tamper protection, no access rules. Neither Kafka nor Postgres is immutable by default, that has to be configured, and nothing here says it was.
Downstream Impact (What breaks if built?)	In an actual FERPA-related investigation, someone could find out the "immutable" log was editable the whole time, turning a compliance requirement into a real legal problem.

Finding 1.5 (Required)

Target Document & Section	Document: Architecture (Exhibit C) Section: Data Architecture vs. Authentication & Security
Taxonomy Code & Category	Code: A Category: Ambiguity
Severity Level	Major (P2)

Quoted Evidence (Verbatim Text)	<i>"Event Store: Apache Kafka — Persistent event log for FERPA audit (Data Architecture) vs. Audit: Kafka audit topic + PostgreSQL audit table (Authentication & Security)"</i>
Diagnosis (Why is this flawed?)	Two different sections each describe what's supposedly the same FERPA audit trail, but they don't agree: one says it's just the Kafka event store, the other says it's Kafka plus a separate Postgres table. Is that the same thing said twice, two redundant stores, or one feeding the other? The document never says.
Downstream Impact (What breaks if built?)	Whoever implements this has to guess which store is the actual system of record. If the two teams each assume the other one owns it, an audit request could come back incomplete.

Finding 1.6 (Optional Bonus Finding)

Target Document & Section	Document: Architecture (Exhibit C) Section: New Services / Access Level Architecture
Taxonomy Code & Category	Code: M Category: Missing / Traceability
Quoted Evidence (Verbatim Text)	<i>"New Services: Form Engine, File Storage, QR Token Service (no role/permission-management service listed)"</i>
Diagnosis & Impact Analysis	The PRD asks for fully dynamic roles plus an admin screen to manage them (FR-33 to FR-36), but the architecture only lists two fixed access levels and no service anywhere handles roles or permissions. That's a fully specified PRD requirement with no owner in the architecture, so it either gets bolted onto some other service later or just gets missed during planning.

Worksheet 2: Team Cross-Document Inconsistency Matrix

Cross-Document Collision 2.1 (Required)

Primary Document A	Document: UX Design Specification (Exhibit B) Section/Clause: 2.3, Success Criteria
Conflicting Document B	Document: Architecture Decision Document (Exhibit C) Section/Clause: Mobile Architecture (Expo/React Native)
Verbatim Quote from Doc A	<i>"Offline Resiliency: QR tokens are valid without active cellular data."</i>
Verbatim Quote from Doc B	<i>"Offline Support: Not required (Phase 1). Deferred to Phase 2."</i>
Nature of the Conflict	UX says QR tokens work offline as part of the main entry flow, and Architecture says offline isn't happening until Phase 2. Same feature, same phase — the two documents just disagree.
Organizational / Architectural Risk	Design and engineering are planning around two different versions of the same feature. If it's built per Architecture, a student with no signal can't get through the gate, breaking the exact experience UX is selling as the headline feature. This is likely to go unnoticed until it's already in testing, or worse, live.

Cross-Document Collision 2.2 (Required)

Primary Document A	Document: UX Design Specification (Exhibit B) Section/Clause: 4.6, Professor Circle Dashboard
Conflicting Document B	Document: PRD (Exhibit A) Section/Clause: DR-2, Privacy Compliance
Verbatim Quote from Doc A	<i>"Participant List: Scrollable list showing user names with visual status indicators."</i>
Verbatim Quote from Doc B	<i>"All contact graph data uses non-reversible anonymous IDs (salted hashing). Real identity mapping stored in a separate, access-controlled vault accessible only to authorized Health Center personnel."</i>
Nature of the Conflict	The UX dashboard shows real user names in the participant list. The PRD says real identity is only ever visible to Health Center staff, through a locked vault. Professors are never given permission anywhere in the PRD to see

	real names. The UX mockup shows exactly what the PRD says should stay hidden.
Organizational / Architectural Risk	Built the way UX describes it, professors would see real student identities that the entire privacy model is designed to hide. That's not just an inconsistency, it undermines the product's central pitch of being privacy-first, and it's the kind of gap that could turn into a real FERPA problem.

Cross-Document Collision 2.3 (Optional Bonus Collision)

Documents & Sections Involved	Doc A: PRD (Exhibit A), FR-33 to FR-36, Access Levels & Dynamic RBAC Doc B: Architecture (Exhibit C), Access Level Architecture
Summary of Conflict & Impact	The PRD wants a fully dynamic role system with an admin panel to manage roles (FR-33 to FR-36). Architecture only has two fixed access levels and no service that manages roles at all — the same gap the Architecture Lead already caught on their own in Finding 1.6, just seen here from the PRD side, which confirms it's a real cross-document problem and not just one person's reading. If nobody owns this, it'll get built as an afterthought instead of being designed properly.

Worksheet 3: Specification Improvement Proposals

Proposal 3.1: Product Requirements Document Improvement

Original Document & Item Ref	Document: PRD (Exhibit A) Section/Requirement ID: FR-17, Campus Entry & Visitor Management
Taxonomy Code & Flaw Summary	Code: C Core Flaw: FR-17 requires linking biometrics to a visitor account, which directly contradicts DR-2/DR-4's guarantee that all contact-graph data uses non-reversible anonymous IDs.
Original Flawed Text (Quote)	<i>"...a secure backend REST API endpoint for creating a local database account and linking biometrics."</i>

Production-Grade Rewritten Specification	FR-17 (Rewritten): Visitor and provider onboarding Precondition: A visitor or provider arrives at a campus entry point, or opens the public onboarding page, without an existing CircleGuard account. Capability: The system lets a visitor or provider self-register a temporary anonymous ID through a web-based flow. No biometric data is collected on the backend, and no biometric identifier is ever linked to the anonymous ID or to the contact graph. Device-local authentication (optional): After registering, the visitor's device can use an on-device biometric or PIN lock just to unlock the CircleGuard app locally. That factor stays on the visitor's own device and is never sent to, or stored by, any CircleGuard backend service. Postcondition (success): The visitor ends up with a valid temporary anonymous ID, usable for entry validation and circle participation, with zero biometric data present in any backend store. Failure handling: If the device has no biometric hardware, or the visitor doesn't want to use one, the app falls back to a normal PIN/password lock with the same functionality. Onboarding is never blocked by the absence of biometric hardware. Acceptance criteria: (1) 100% of visitor onboarding backend requests, audited across the whole API, contain zero biometric fields or hashes. (2) A visitor can complete registration and get a working anonymous ID in the same session, on a device with no biometric hardware. (3) The anonymous ID generated for a visitor looks and is stored exactly like an anonymous ID for any other persona type.
Engineering Rationale & Justification	Separating device-local authentication from the server-side identity resolves the contradiction without losing the convenience of biometric unlock: the fingerprint or face scan just unlocks the phone, it never becomes part of the identity the server sees. That keeps DR-2/DR-4's non-reversible anonymous ID guarantee intact end to end, including for visitors, who have the least institutional protection of any persona group.
Verification & QA Acceptance Plan	Automated: a test suite intercepts every onboarding-related API call in staging and asserts zero biometric-related fields across 100% of requests. Manual: a penetration test tries to trace a device's biometric factor back to any server-side record; the test only passes if no such trace can be found.

Proposal 3.2: UX Design Specification Improvement

Original Document & Item Ref	Document: UX Spec (Exhibit B) Section/Component ID: 4.6, Professor Circle Dashboard — Participant List
Taxonomy Code & Flaw Summary	Code: I Core Flaw: the Participant List shows "user names" with no defined authorization scope, exposing real identities that the PRD reserves for Health Center personnel only.
Original Flawed Text (Quote)	<i>"Participant List: Scrollable list showing user names with visual status indicators."</i>
Production-Grade Rewritten Specification	Component: Participant List (Professor Circle Dashboard) Component anatomy: A vertically scrollable list. Each row shows: (1) a Hash Avatar (per Section 5.2), (2) a role-appropriate participant label, (3) a status pill (Checked-in / Pending / Fenced), (4) a timestamp of the last status change. Identity display rule: The label shows the anonymous ID's short hash by default (e.g., "Participant #4F2A") for every role. Real names are never rendered in this component, not even for Professor or Admin — resolving real identity stays out of scope for this dashboard and remains exclusive to the Health Center de-identification console (per DR-2/DR-4). UI states: • Loading: skeleton rows shown while the list fetches; no partial or stale data displayed. • Success: full list rendered with Hash Avatars, labels, and status pills. • Empty: a centered message ("No participants checked in yet"), no error icon. • Error: an inline retry banner ("Couldn't load participants — Retry") replacing the list; no stale data shown silently. Accessibility: Each row carries an ARIA label combining the anonymous label and status (e.g., "Participant 4F2A, Checked in"). Status is never conveyed by color alone — the status pill always pairs its color with a text label (WCAG 2.1 AA, 1.4.1). Minimum 48x48px tap target per row. Loading and error states are announced through an ARIA live region. Acceptance criteria: (1) A UI audit across every role (Student, Professor, Admin, Health Center) confirms zero occurrences of a real name in this component outside Health Center. (2) A VoiceOver/TalkBack read-through correctly announces label + status for 100% of rows. (3) All four UI states (loading, success, empty, error) are reachable and visually distinct in component testing.

Engineering Rationale & Justification	Deciding that this component never shows real names, instead of trying to gate visibility per-role inside the same component, removes the ambiguity at the root and avoids creating a second authorization path alongside the Health Center vault. It keeps exactly one place in the whole system able to resolve real identity, which matches how the rest of the PRD is already built.
Verification & QA Acceptance Plan	Automated: an accessibility test (Axe-core) run against each of the four states, plus a test confirming the rendered DOM never carries a real-name field outside Health Center sessions. Manual: a VoiceOver and TalkBack audit confirms every row's status is understandable without relying on color, and that loading/error transitions are announced.

Proposal 3.3: Architecture Decision Document Improvement

Original Document & Item Ref	Document: Architecture (Exhibit C) Section/Decision Area: Mobile Architecture (Expo/React Native) — Offline Support
Taxonomy Code & Flaw Summary	Code: X Core Flaw: Architecture defers all offline support to Phase 2, directly contradicting UX 2.3's Phase 1 success criterion promising offline QR validity.
Original Flawed Text (Quote)	<i>"Offline Support: Not required (Phase 1). Deferred to Phase 2."</i>

Production-Grade Rewritten Specification	ADR-11: Scoped offline support for entry-token validation (Phase 1) Context: UX (Section 2.3) promises "Offline Resiliency: QR tokens are valid without active cellular data" as part of the product's main experience (Frictionless Campus Entry). The original Architecture draft pushed all offline capability to Phase 2 with no scoping, creating a direct Phase 1 contradiction with UX and, by extension, with PRD FR-15/FR-16 (entry validation). Decision: Phase 1 ships a narrowly scoped offline mode limited to displaying and locally validating the entry token. Everything else (symptom reporting, circle creation, dashboards) stays online-only in Phase 1, unchanged from the original architecture. Rationale: A full offline-first rearchitecture (local graph cache, replication) is way more than UX actually asks for — the promise is scoped to the entry-gate flow, not the whole app. Limiting the offline guarantee to the token display keeps Phase 1's scope small while closing the contradiction. Mechanism: The signed, time-limited QR token (FR-30/FR-32) gets cached on the device as soon as it's generated, along with its signature and expiry time. While offline, the app shows the last cached, non-expired token without any network call. Gate terminals validate the token's signature and expiry locally against the shared signing key; no live backend call is needed. Cache invalidation / consistency rule: A cached token is only valid offline until its normal 5-minute expiry (FR-32) runs out; being offline doesn't extend that window. On reconnection, the app immediately requests a fresh token and drops the cached one. If there's no valid cached token while offline, the app shows a distinct "Reconnect to refresh entry pass" state instead of a stale or invalid token. Trade-offs: This keeps UX's headline promise and closes the cross-document contradiction, at the cost of gate terminals needing local signature-validation capability (distributing the public key to terminals) instead of a simple server round-trip. It explicitly doesn't extend offline support to symptom reporting, circle joining, or any write-path feature — those stay online-only, so the fix stays bounded instead of reopening the whole offline question UX never actually raised. Traceability: Satisfies UX 2.3 (Offline Resiliency) and PRD FR-15/FR-16 (entry validation) for Phase 1. Doesn't change NFR-3 (API latency) or NFR-4 (uptime), since the offline path is additive and doesn't touch the online validation path.
Engineering Rationale & Justification	Scoping the fix to just the entry-token path, instead of declaring the whole app "offline-capable," avoids overcorrecting into a Phase-2-sized rearchitecture just to fix a Phase 1 documentation contradiction. It leaves

	UX and Architecture with the same, single, precisely bounded claim about what "offline" means in Phase 1.
Verification & QA Acceptance Plan	Automated: a deliberate network-disconnect test (airplane mode) verifies the app shows, and gate terminals accept, a cached non-expired token; a second test verifies an expired cached token gets rejected locally and the app shows the reconnect state. Manual: a terminal-side audit confirms signature validation works with no outbound call during the disconnect window, and that reconnecting triggers an immediate token refresh that drops the cached one.